

Web Application Hacking

What is web application? - A web application (or web app) is application software that runs on a web server, unlike computer-based software programs that are

run locally on the operating system (OS) of the device. Web applications are accessed by the user through a web browser with an active network connection.

How web application works? - A web application functions works in two steps, Front-end and Back-end these are the two function every web application use.

Users are interacting with the front-end all user requests is handled by front-end.

All processing was controlled and processed by the back-end.

Front-end/Client side languages:

HTML

CSS

Javascript

Back-end/Server-side languages:

PHP

Java

C#

Javascript

Python

Owasp Top 10 2017

1. **Injection** - Injection occurs when attacker are able to inject malicious command, scripts, queries etc.
2. **Broken Authentication** - When some applications are implemented incorrectly, It allows an attacker to compromise login pages, passwords and sessions.
3. **Sensitive Data Exposure** - Sensitive data exposure happens when important stored or transmitted data is compromised.
4. **XML External Entities(XXE)** - XXE Happens when application is using vulnerable component processing XML.
5. **Broken Access Control(Authorization)** - Broken access control happens when attacker is able to get access to other users accounts. It can be normal user or admin.
6. **Security Misconfiguration** - It happens when something is implemented incorrectly, like default users, default passwords, misconfigured headers etc.
7. **XSS(Cross-Site Scripting)** - Executing Java Script, PHP or any Language code/scripts on web application is known as Cross-Site Scripting.
8. **Insecure Deserialization** - When user-controllable data is deserialized by a website. This potentially enables an attacker to manipulate serialized objects in order to pass harmful data into the application code.
9. **Using components with known vulnerabilities.**
10. **Insufficient logging and monitoring.**

Burpsuite :

Burp or Burp Suite is a set of tools used for penetration testing of web applications.



Intruder tab :

Payload position type -

- 1. Sniper will work on one point.**
- 2. In battering ram we will use single wordlist in different points.**
- 3. In Pithfork we will use multiple wordlist for multiple positions both the wordlist will go simultaneously.**
- 4. In cluster bomb we can use different and multiple wordlist on different different parameter and it will bruteforce first username with every password and then go with another one.**

DVWA Lab :

We will perform testing on this vulnerable lab.

